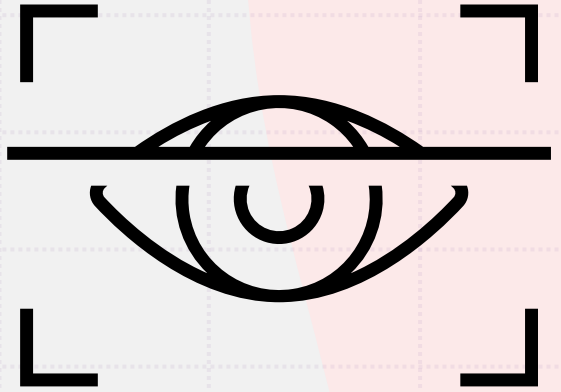
SOFTWARE BASED SIDE CHANNEL ATTACKS AND DEFENSES: Introduction



Ali Tashfeen

mxalitashfeen@shockers.wichita.edu

Wichita State University

February 16, 2023

What is a Side Channel?



Real-life examples (Cont.)

- Source
  - https://abc7.com/snow-lack-of-drug-bust-the-netherlands/514461/



Real-life examples

Safe has two visible states

Open

Closed

But there is more information

Correct digit ⇨ lock clicks

Stethoscope detect it



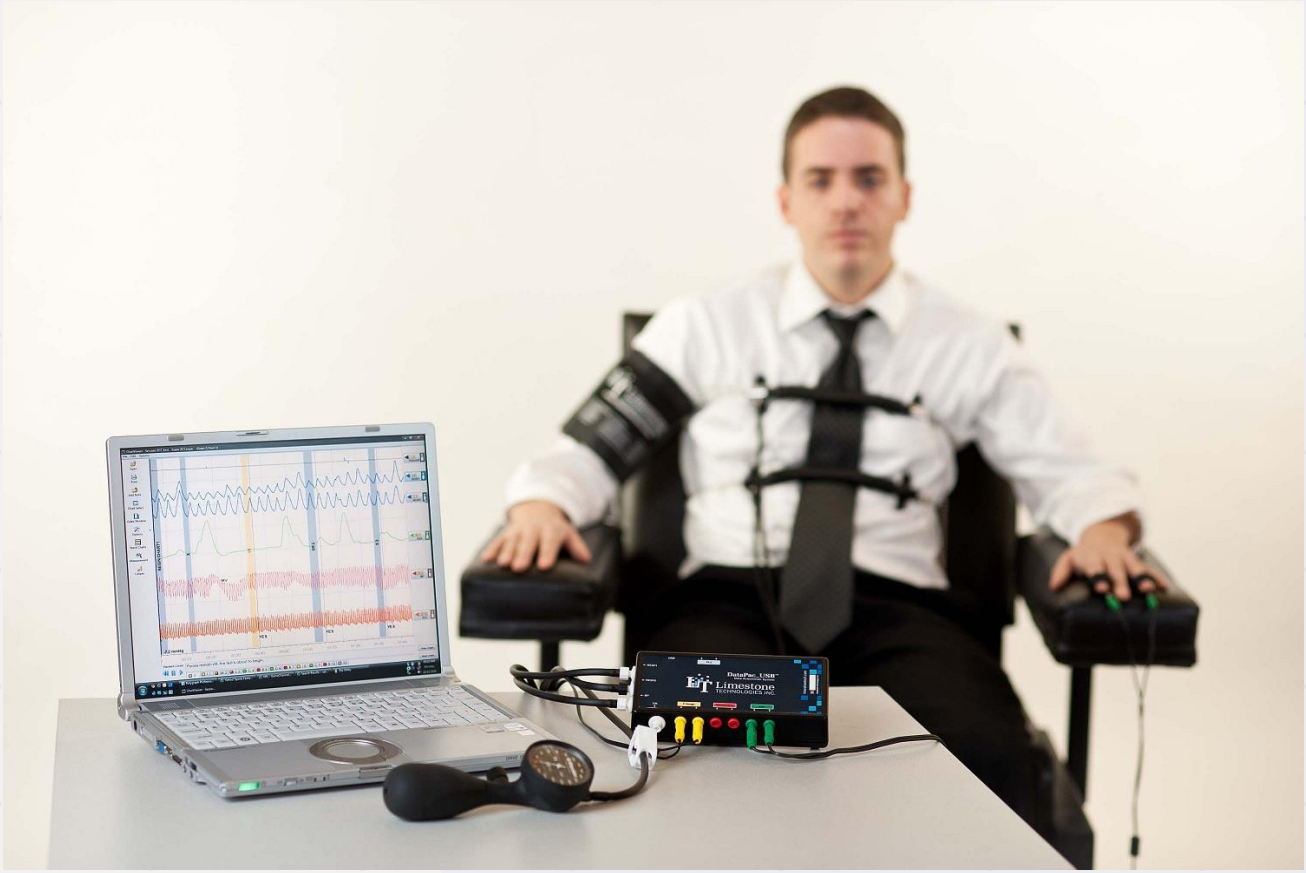
Humans SCA

- Tone
- Breathing
- Sweating
- ..
- Conditions to pick them???



Human Side-Channel Analysis

- Heart rate, blood pressure, respiration, and skin conductivity.



Opportunities for SCA

IT systems have a vast attack surface due to their intricate hardware and software components, making them susceptible to various forms of side-channel exploits.

Side-Channel Attacks on IT Infrastructure



Various Sources of Information are utilized that are beyond primary comminication



Secure main data pathways but not consider others??

The Goal of SCA

Encryption keys

Passwords, or

Personal identifiable Information(PII)

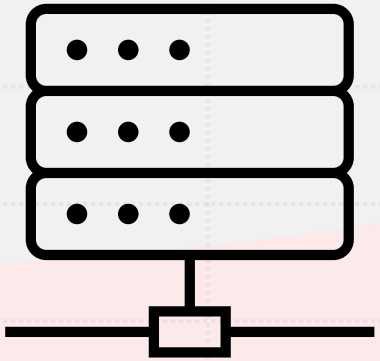
Secret data

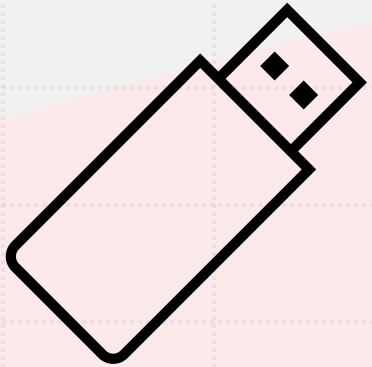
User activity (visited websites, running programs, …)

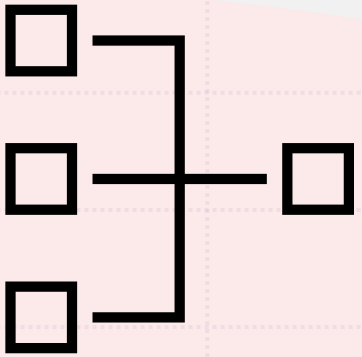
Keystroke Timings

……..!

Intended communication channel







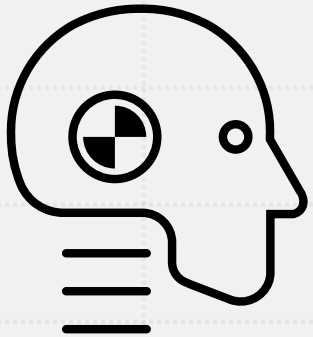
Concepts related to side-channel attacks

Term	Explanation
Side Channel Attack	A type of cyber-attack where the attacker gains information from the physical implementation of a system, rather than weaknesses in the software itself.
Side Channel	The unintended communication path that leaks information. This could be anything from power consumption, electromagnetic leaks, sound, or even timing information.

Concepts related to side-channel attacks

Term	Explanation
Information Leakage	The process by which sensitive information is unintentionally exposed through a side channel, allowing attackers to gain insights into the system's operations or secrets.
Side Channel Analysis	The technique of analyzing information gained from side channels to uncover secrets or vulnerabilities in a system, often used in side-channel attacks.

Covert Channel



Term	Explanation	Covert Channel
Side Channel Attack	An attack exploiting physical system implementations to gain information, bypassing software weaknesses.	A method where information is transmitted secretly using a channel not intended for communication, often between processes within a system.
Side Channel	An unintentional path that leaks information through physical means like power, electromagnetic signals, sound, or timing.	A hidden path that allows the transfer of information in a manner violating the system's security policy.
Information Leakage	The accidental exposure of sensitive information through side channels, revealing system operations or secrets.	The unintended and unauthorized transmission of information across the covert channel.
Side Channel Analysis	Analyzing leaked information from side channels to uncover system vulnerabilities or secrets.	The process of detecting and decoding messages passed through covert channels, often to breach security protocols.

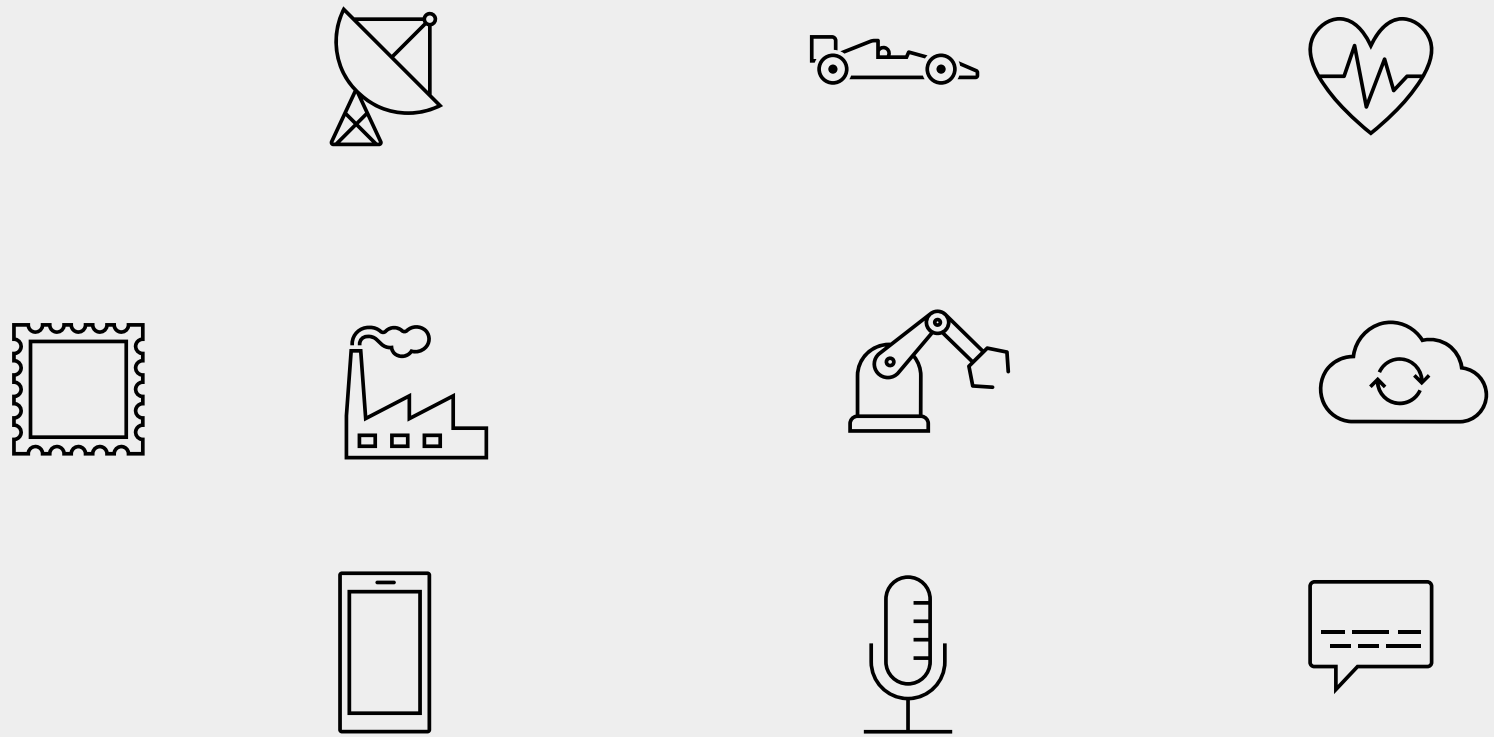
Motivation

- CIA Triad
- Role Based Access Control
- Access Control Matrix
- 2FA
- NIST SPs
- PCI DSS
- Firewalls/IDS/IPS/SIEM
- ……

- **Are these enough to defend against Side channel attacks?**

Scope that cross Cryptographic Systems

T. George Hornby. “Side-Channel Attacks on Everyday Applications: Distinguishing Inputs with FLUSH+RELOAD”. In: 2016.

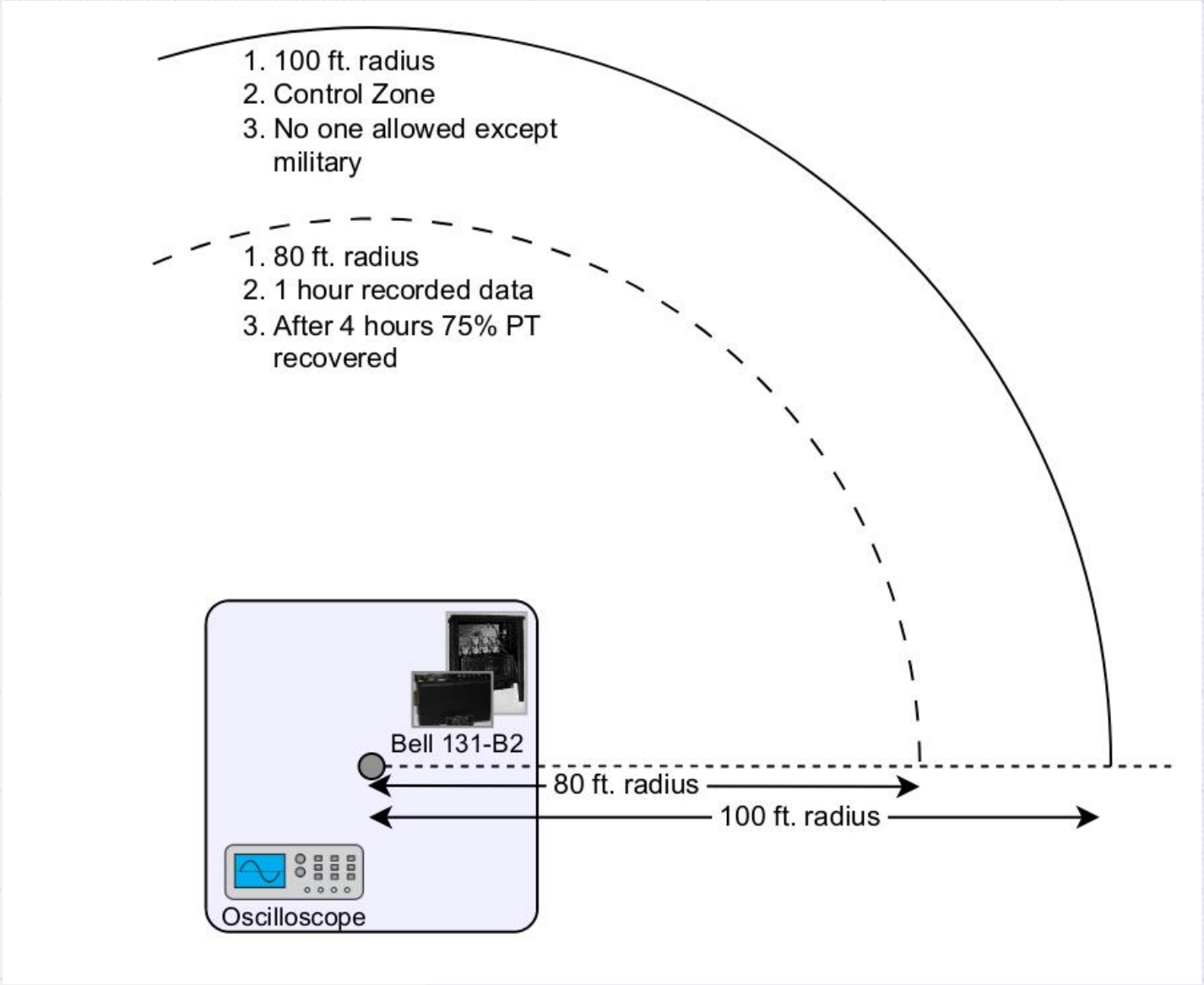


SCA Techniques

Power	Time Electromagnetic Radiations	Acoustic Cryptanalysis	Cache-Based Attacks
Rowhammer Attack	Fault Injection	Hardware Trojon	Photon Emission Analysis

TEMPEST

- Telecommunications Electronics Material Protected from Emanating Spurious Transmissions (TEMPEST)
- An approved document for release by NSA in 2007 in response to the Freedom of Information Act (FOIA) request to the Department of Defense, USA.



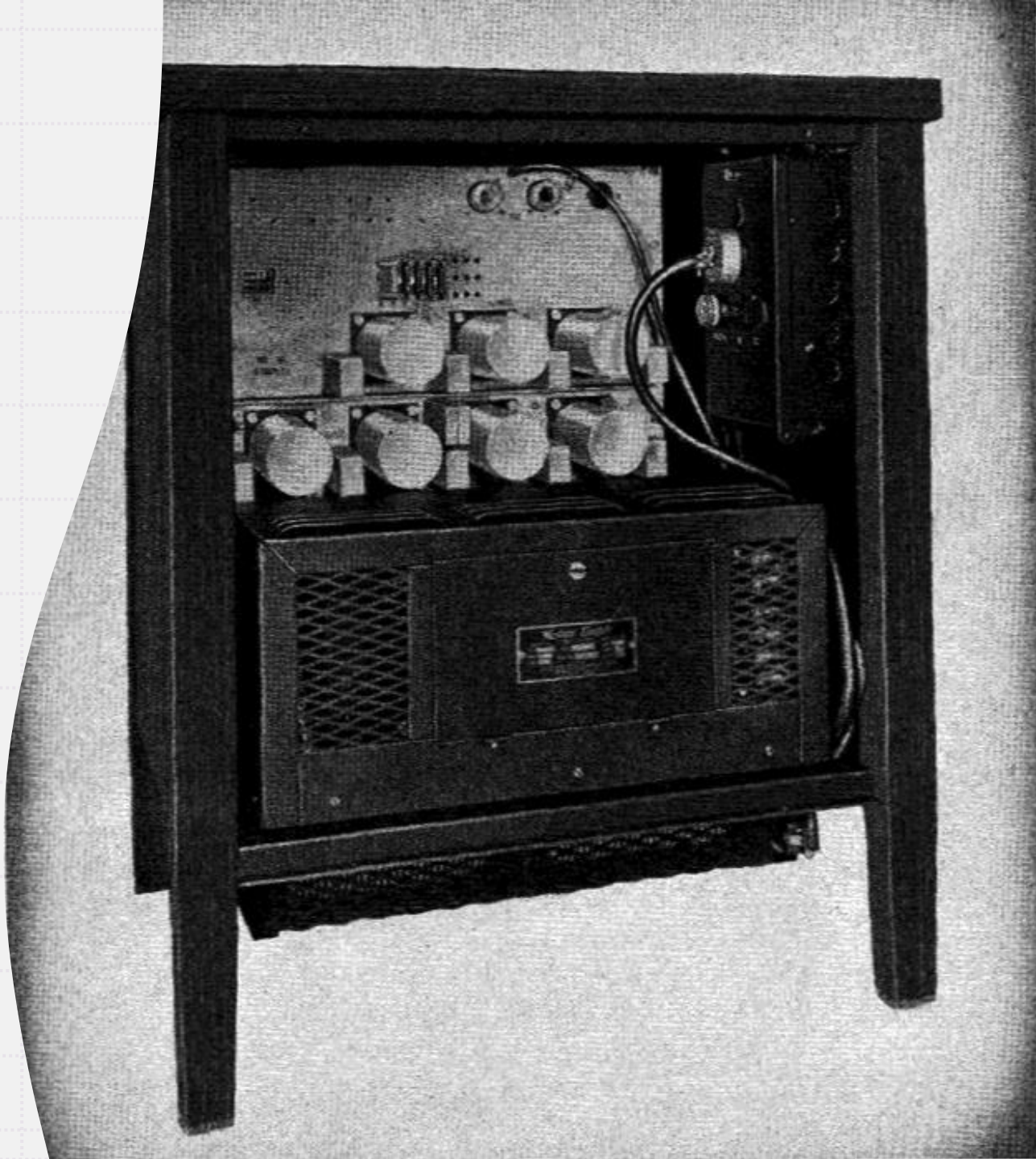
Source:http://arxiv.org/abs/2312.11094

Bell 131-B2 Mixing Devices

Shielding

Filtering

Masking





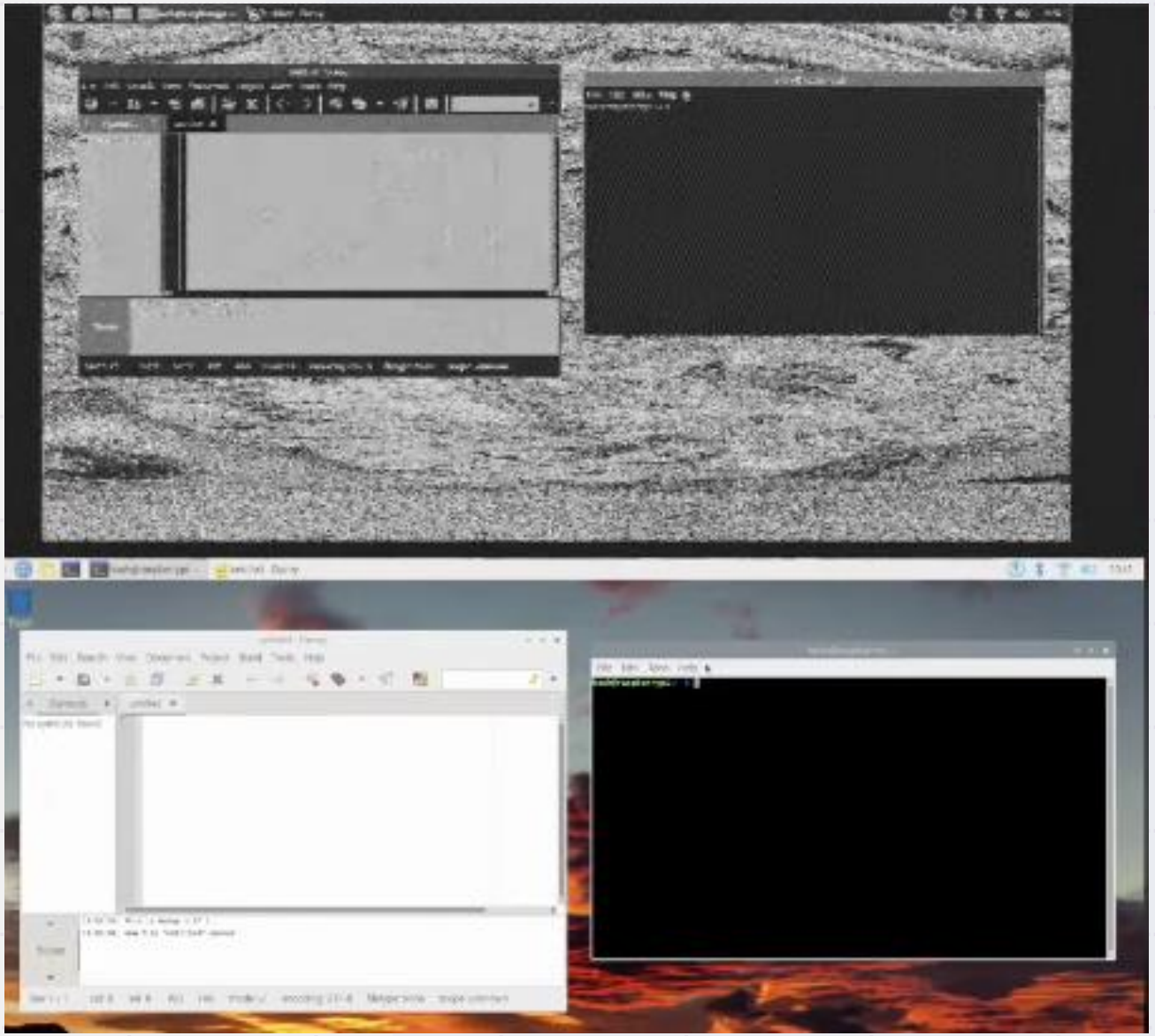
Source: https://hackaday.com/2015/10/19/tempest-a-tin-foil-hat-for-your-electronics-and-their-secrets/

Electromagnetic Radiation from Video Display Units: An Eavesdropping Risk?" by Wim Van Eck

- CRT (Cathode Ray Tube)
- Programmable Digital Frequency Divider
- Mitigation Strategies
  - Minimization of Radation
  - Maximization of noise
  - Cryptographic displays

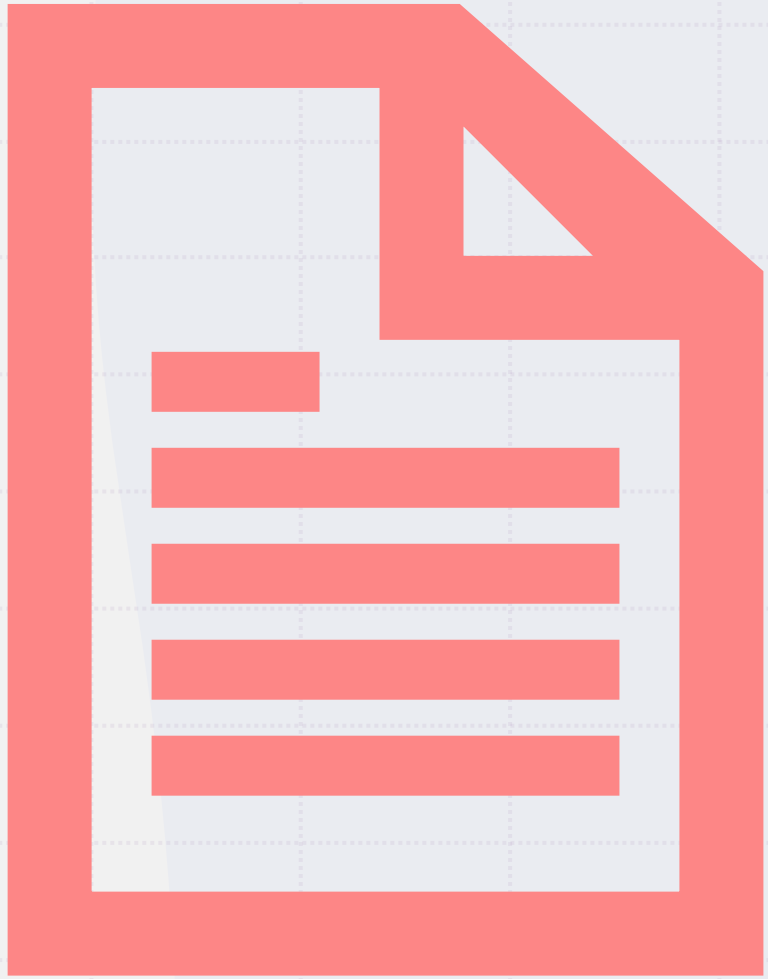
Van Eck phreaking

- Software Defined Radio



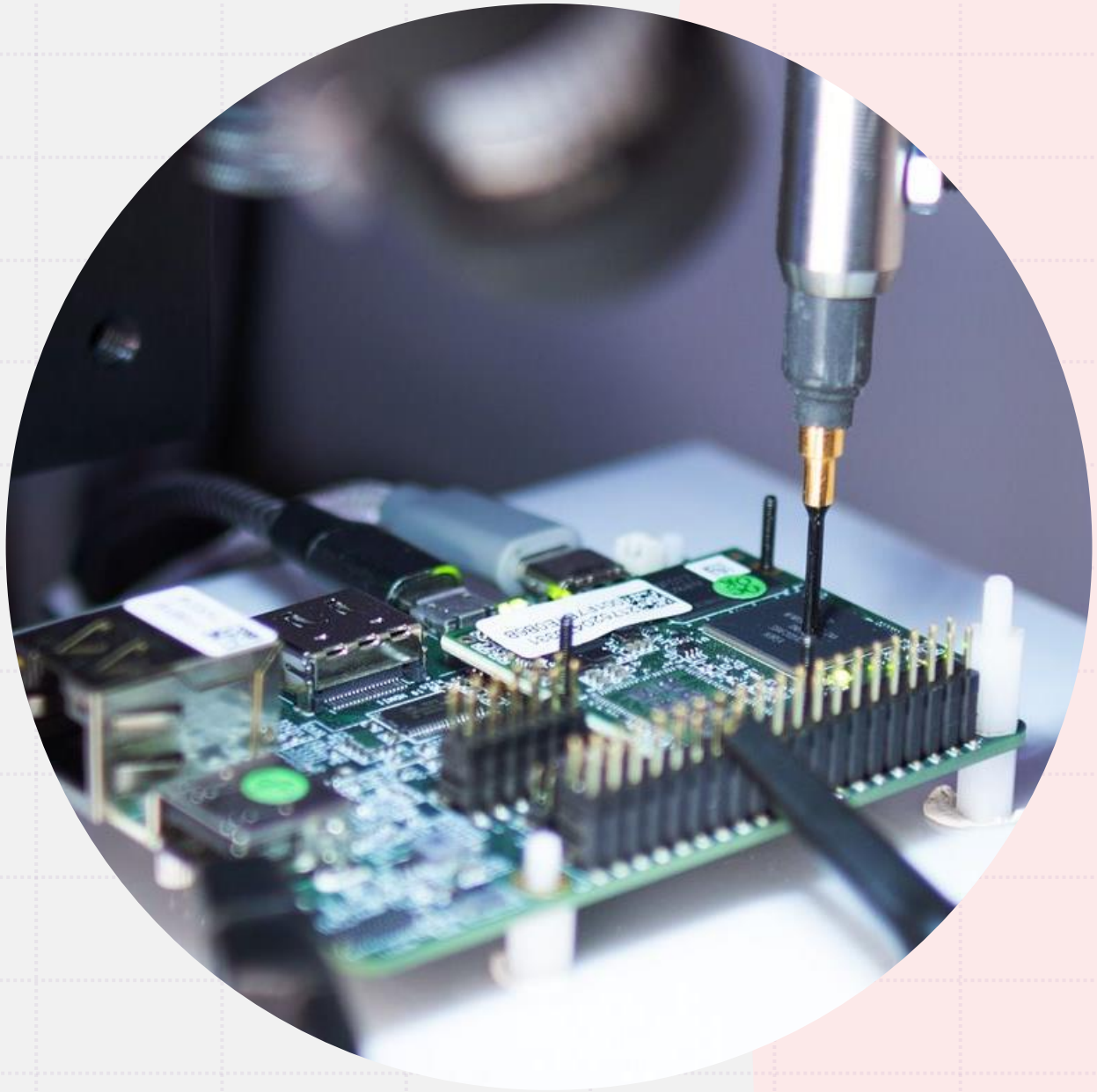
Unveiling the Pinnacle Achievements of Side Channel Attacks

- 1996
- The Paper: Timing Attacks on Implementations of Diffie-Hellman, RSA, DSS, and Other Systems

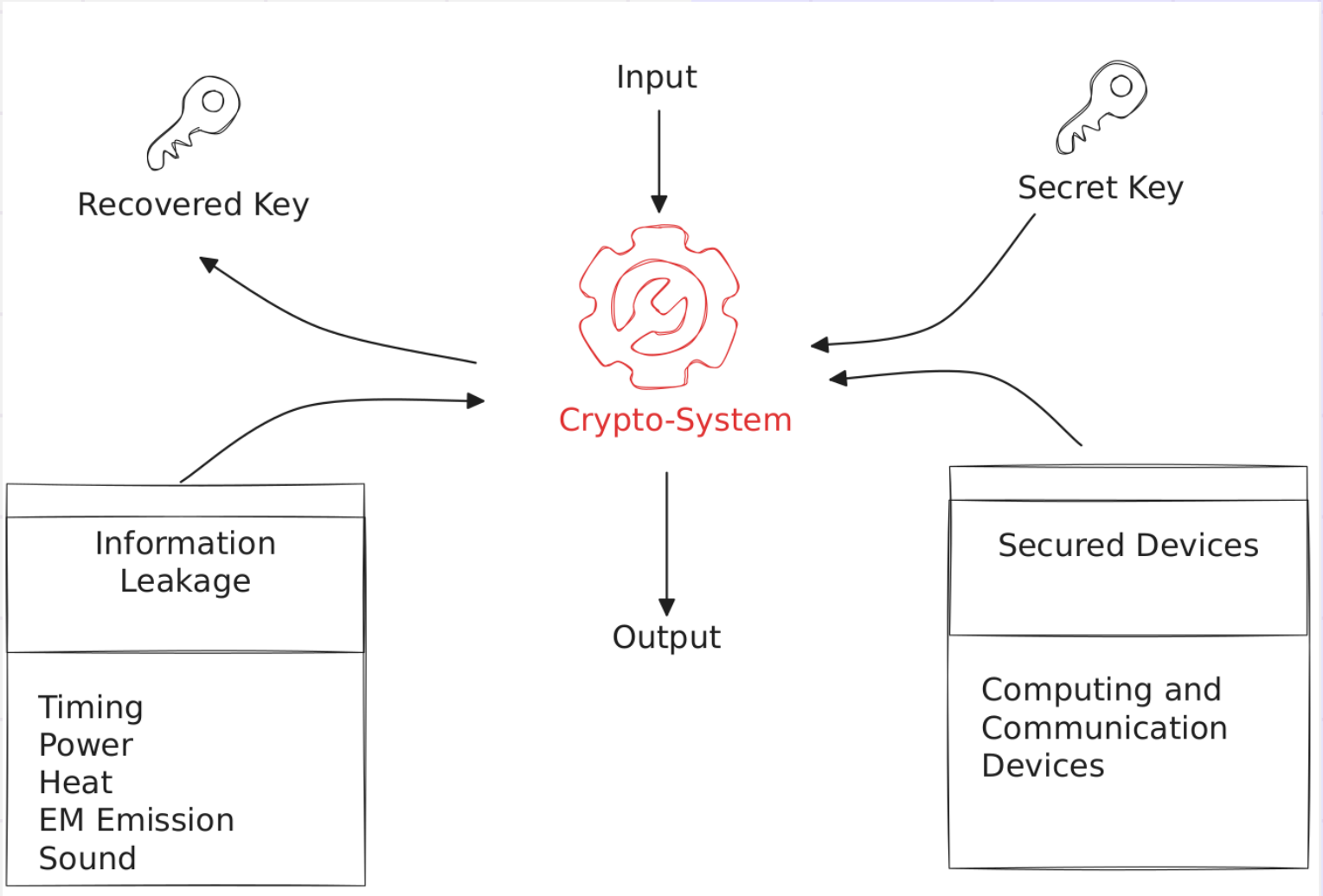


Measured quantity can lead to information leakage, and this is how various side-channels were introduced.

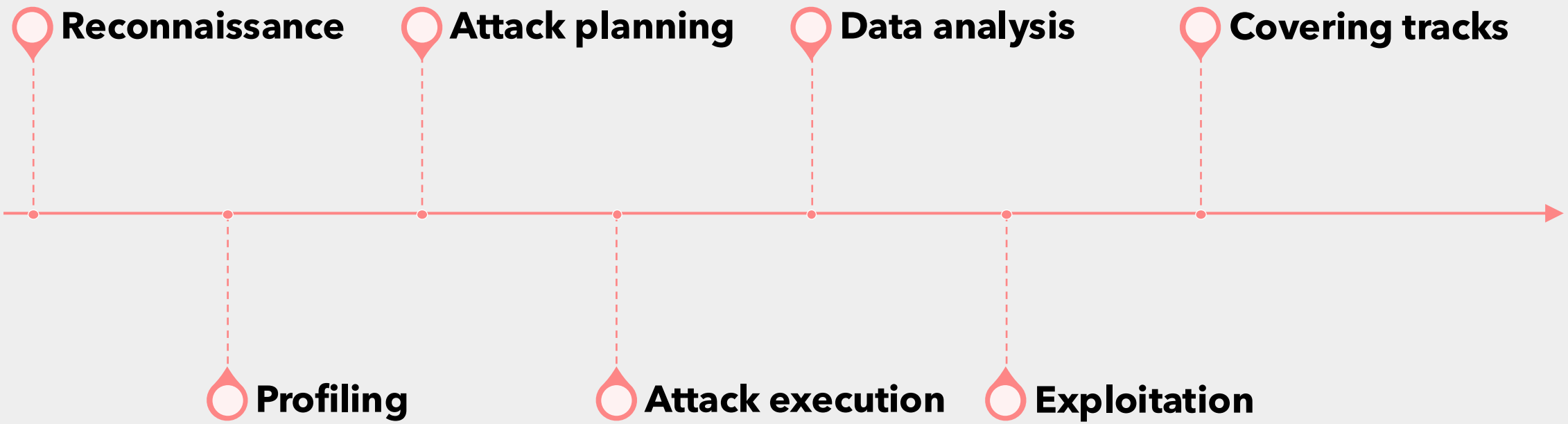
- Manfred Josef Aigner and Elisabeth Oswald. “Power Analysis Tutorial”. In: Institute for Applied Information Processing and Communication, University of Technology Graz, 2000.

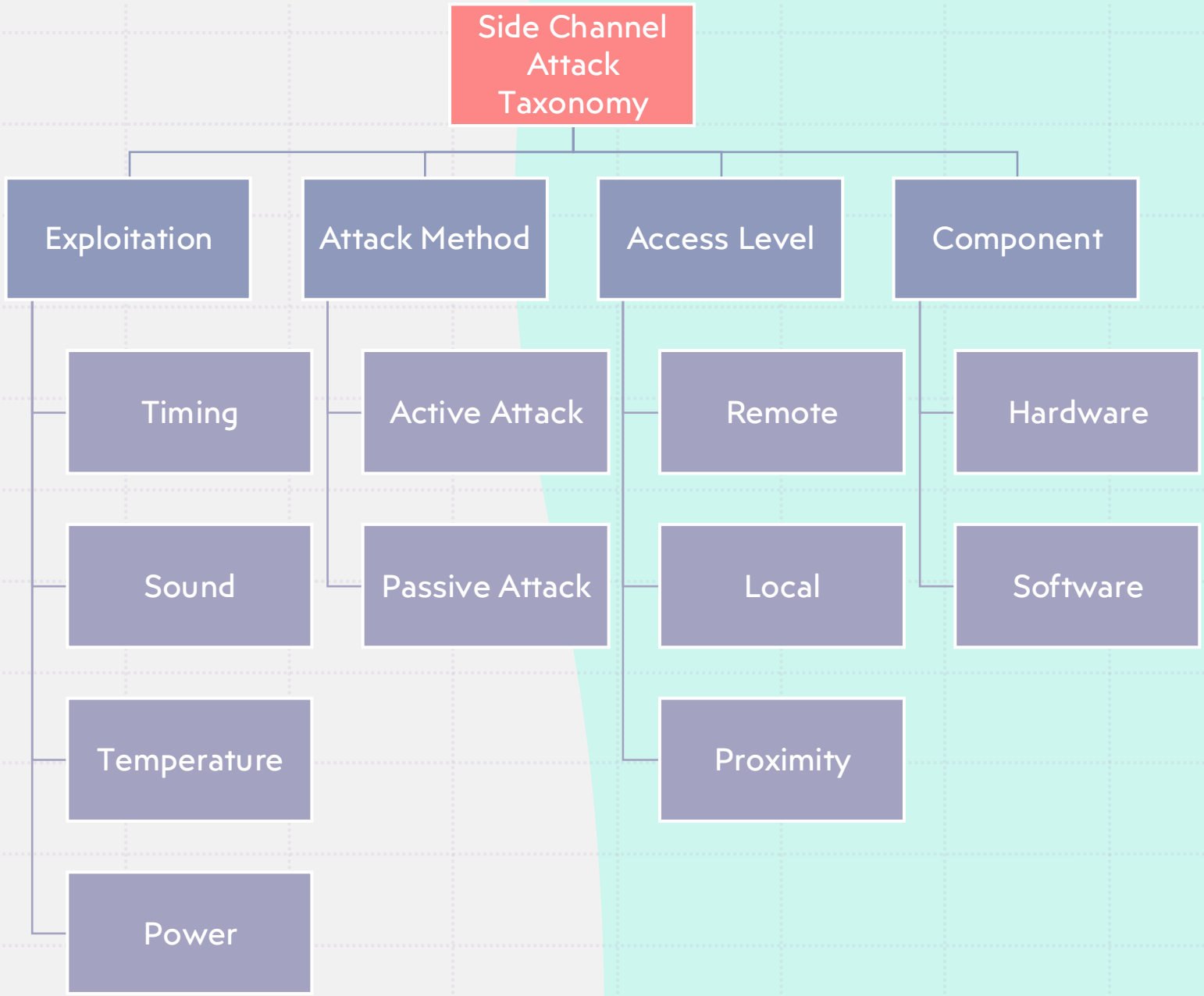


SCA


Input
Recovered Key
Secret Key
Crypto-System
Output
Information Leakage
Timing
Power
Heat
EM Emission
Sound
Secured Devices
Computing and Communication Devices

SCA Model


Reconnaissance
Attack planning
Data analysis
Covering tracks
Profiling
Attack execution
Exploitation


Side Channel Attack Taxonomy
Exploitation
Attack Method
Access Level
Component
Timing
Sound
Temperature
Power
Active Attack
Passive Attack
Remote
Local
Proximity
Hardware
Software

SCA Classification

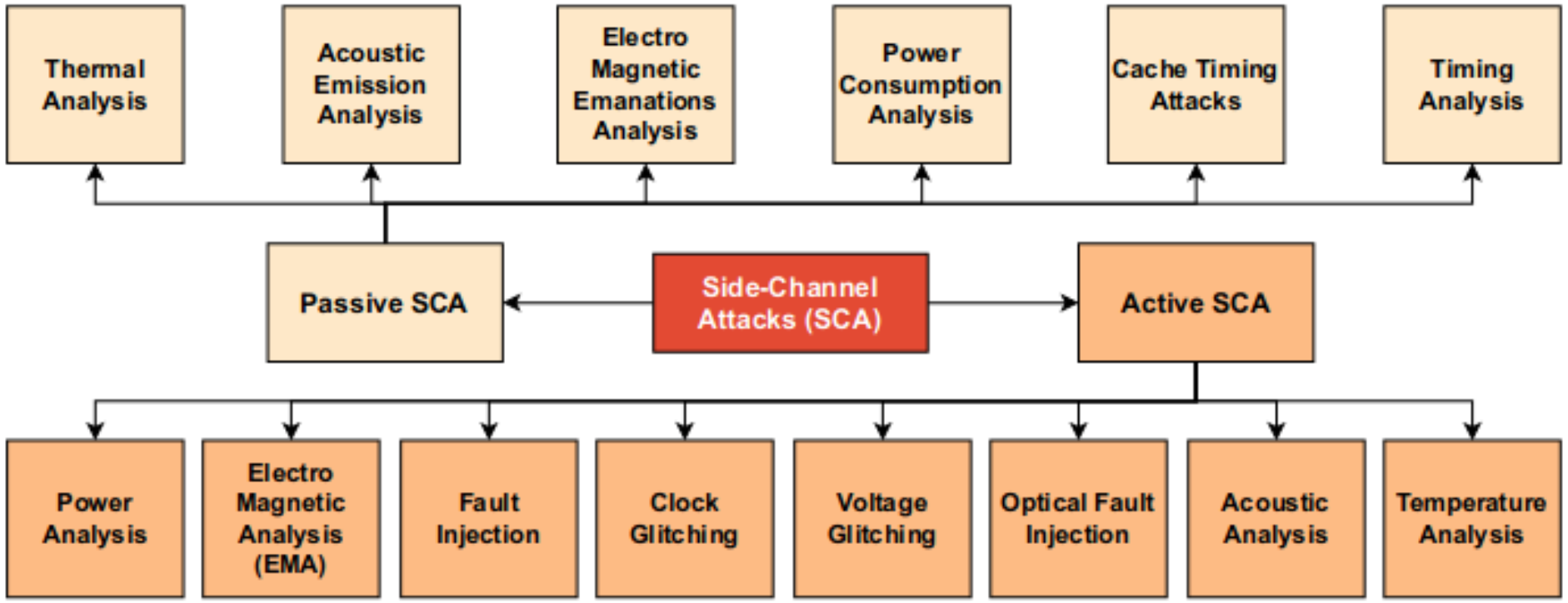
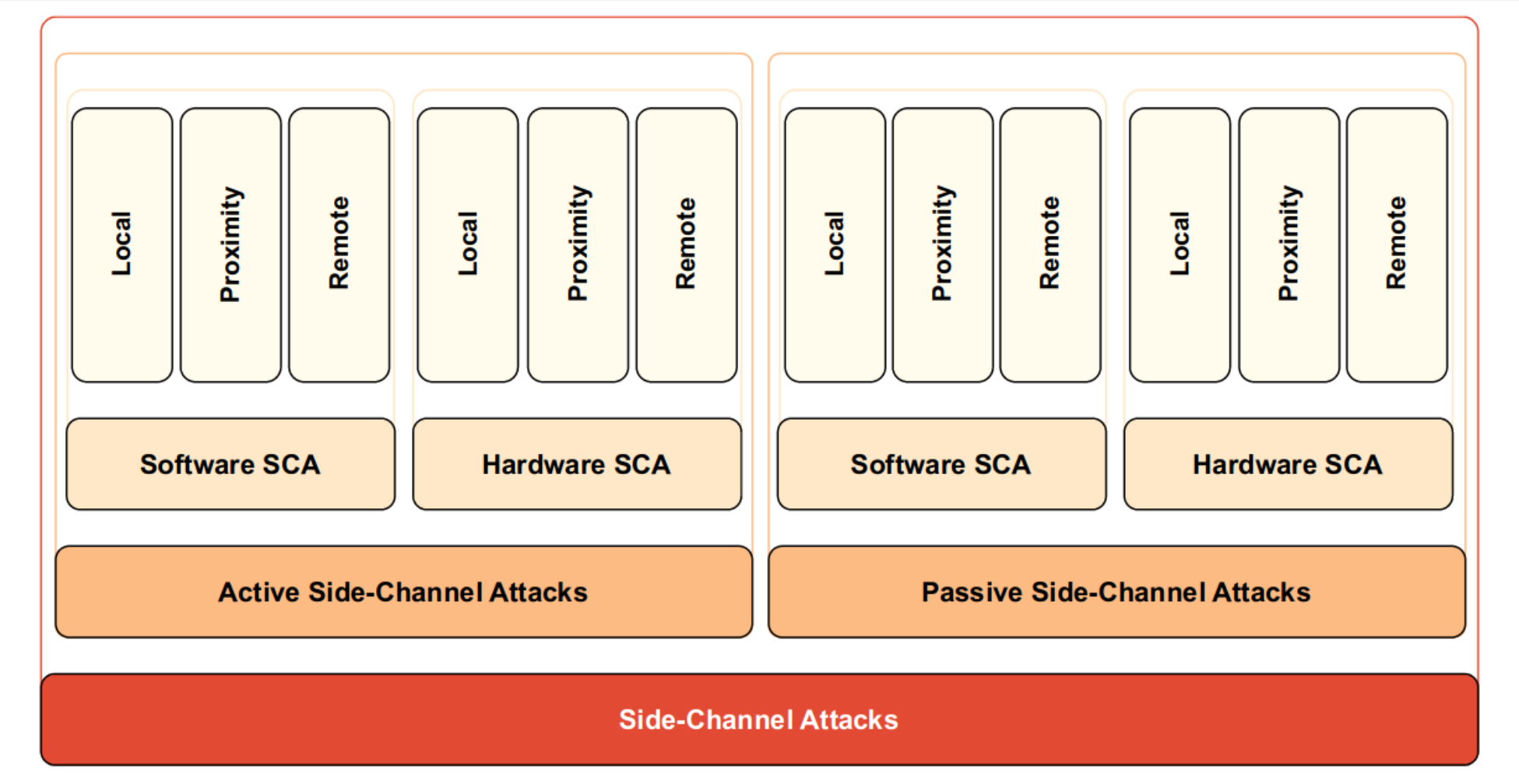


Fig. 8: Active and Passive SCA Classification

Source: http://arxiv.org/abs/2312.11094

Overall Side-channel Taxonomy



Case Study

- ATM PIN
- 4 Digits



Python function to check a 4-digit PIN

timing attack.py > check_pin

```python
# A simple PIN check function that's not secure against timing attacks.
def check_pin(input_pin):
    # The actual PIN the user needs to match.
    correct_pin = "1234"

    # Check if the input PIN is exactly 4 digits.
    if len(input_pin) != 4:
        return False

    # Check each digit of the input PIN against the correct PIN.
    for i in range(4):
        # If any digit is wrong, return False immediately.
        if input_pin[i] != correct_pin[i]:
            return False

    # If all digits are correct, return True.
    return True

```

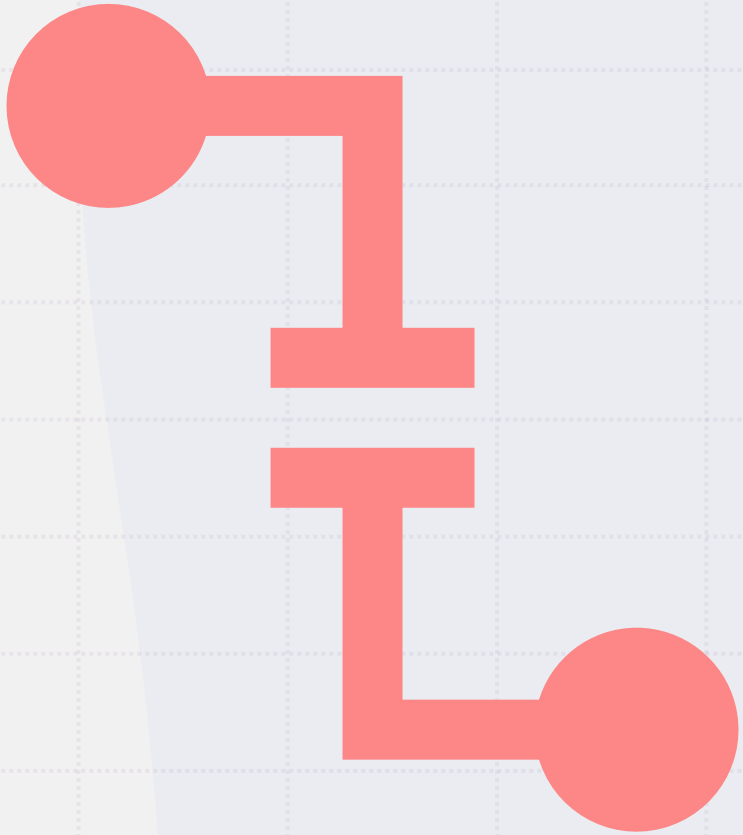
Timing Analysis

- **Correct PIN ("1234")**: Approximately 0.042 seconds
- **Wrong PINs**:
- "1235": Approximately 0.042 seconds
- "1244": Approximately 0.040 seconds
- "1344": Approximately 0.021 seconds
- "2344": Approximately 0.011 seconds



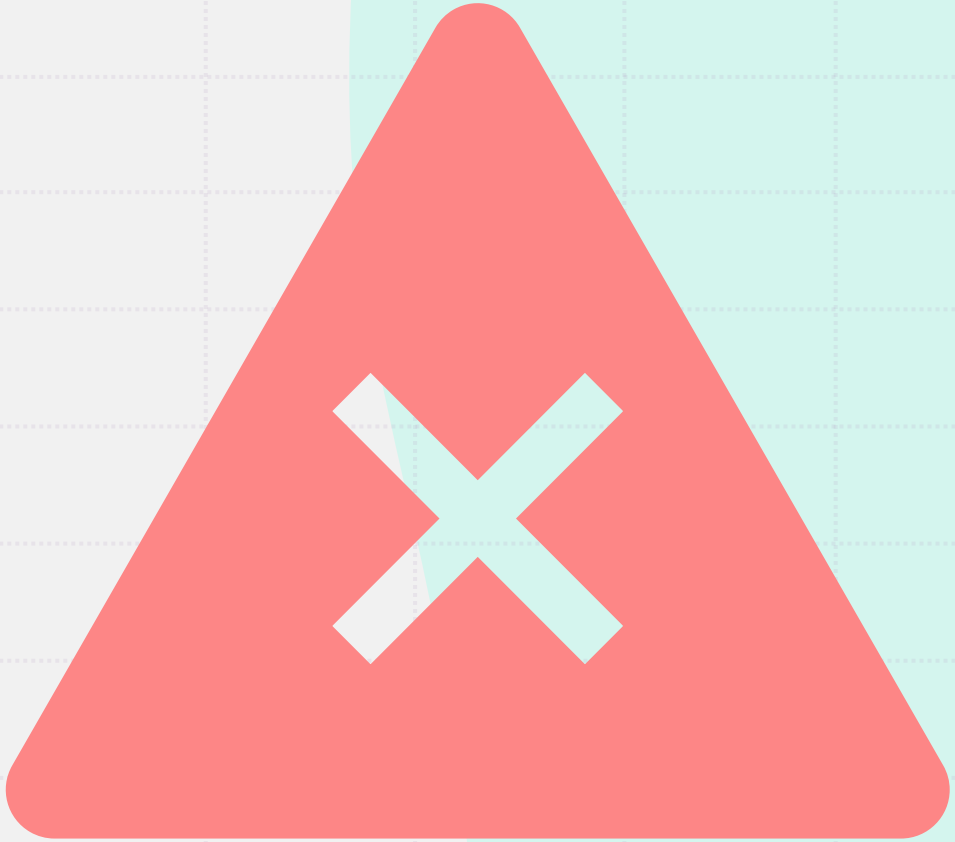
Code Analysis

- The code runs fast and exit early!!!
- Input Dependent
- This Allows the Attacker to guess the password from timing



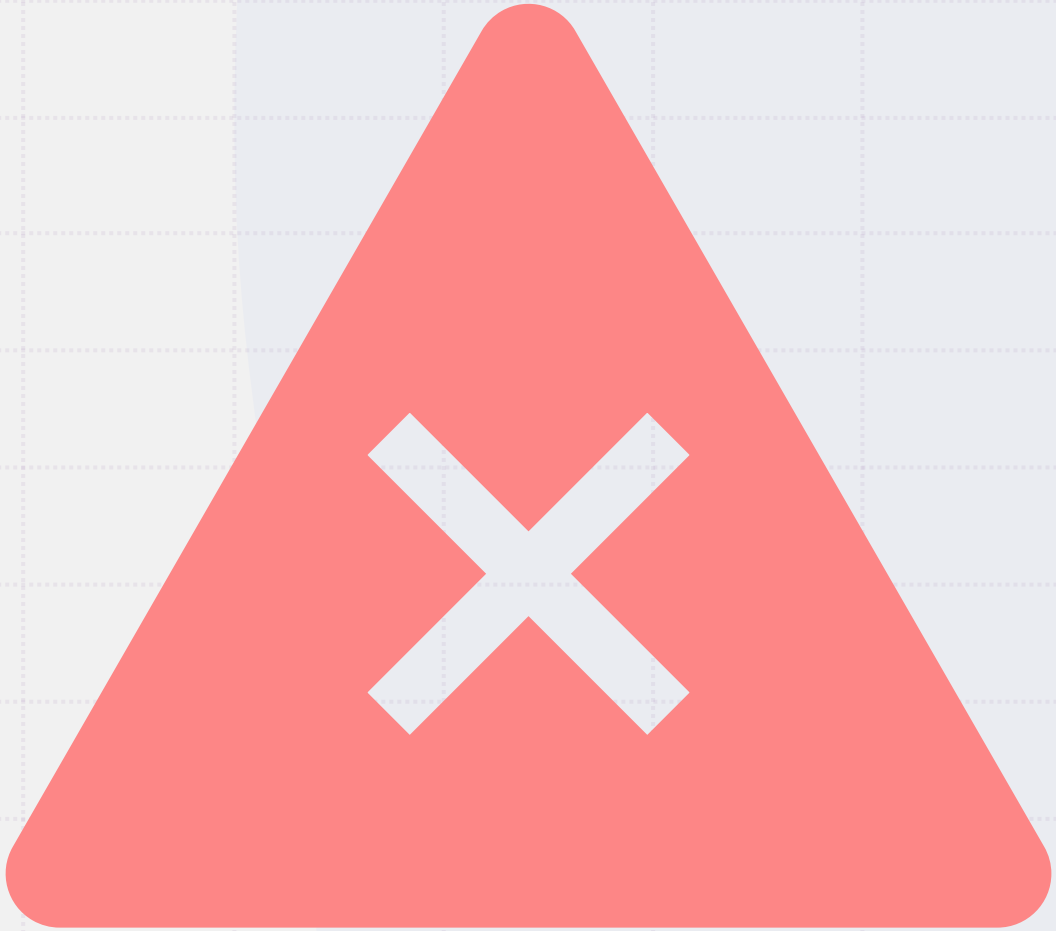
Mitigation

- Don’t exit early
- Remove Branches
- Try to achieve Contant time code O(1)



Mitigation

- Understand Vulnerabilities
- Security Training
- Physical Isolation
- Process and Memory Isolation
- Reduce Attack Surface
- Randomization ASLR



CVE-2023-32691



gost (GO Simple Tunnel) is a simple tunnel written in golang.



Untrusted input, sourced from a HTTP header, is compared directly with a secret. Since this comparison is not secure, an attacker can mount a side-channel timing attack to guess the password.

Questions

